

LA PLUMA ENGINEERING

Actionable Roadmap

Production Remediation Roadmap & Actionable Backlog

Prioritized Technical Debt, Security Hardening & Pre-Deployment Task Matrix

This actionable engineering document provides concrete, prioritized remediation tasks addressing all critical (P0), high (P1), and medium (P2) findings identified during the multi-agent Devil's Advocate audit. Each task defines explicit file locations, code snippets, diffs, and verification criteria.

ACTION ITEMS

22 Prioritized Engineering Tasks

TARGET REPOSITORIES

PEN-lapluma_app & PEN-lapluma_infra

EXECUTION PHASING

P0 Immediate Blockers · P1 Sprint 1 · P2 Sprint 2

PUBLICATION DATE

September 18, 2026

Category 1: P0 Immediate Deployment Blockers (Fix Before Any Release)

TASK-P0-01: Implement Cryptographic XML Signature Validation in SAML Provider

Target: [PEN-lapluma_infra/src/core-api/Auth/SamlServiceProvider.cs](#) (Lines 223–228)

Defect: The current code checks for the existence of `ds:Signature` without cryptographically verifying the digest or certificate.

```
// REPLACE:
var signatureElem = assertionElem.Element(ds + "Signature");
if (signatureElem == null) return Failure("unsigned-assertion");

// WITH:
var xmlDoc = new XmlDocument { PreserveWhitespace = true };
xmlDoc.LoadXml(assertionXml);
var signedXml = new SignedXml(xmlDoc);
var signatureNode = xmlDoc.GetElementsByTagName("Signature", SignedXml.XmlDsigNamespaceUrl)[0];
signedXml.LoadXml((XmlElement)signatureNode);
if (!signedXml.CheckSignature(idpCertificate, verifySignatureOnly: false)) {
    return Failure("invalid-signature", "Cryptographic signature validation failed");
}
```

TASK-P0-02: Replace Unsigned Base64 Token with Cryptographically Signed JWT

Target: [PEN-lapluma_infra/src/core-api/Auth/SamlServiceProvider.cs](#) (Lines 351–353)

```
// REPLACE:
var token = "lp_saml_" + Convert.ToBase64String(Encoding.UTF8.GetBytes(...));

// WITH:
var tokenDescriptor = new SecurityTokenDescriptor {
    Subject = new ClaimsIdentity(new[] {
        new Claim("tid", assertion.TenantId),
        new Claim(ClaimTypes.Email, assertion.Email),
        new Claim(ClaimTypes.Role, string.Join(",", assertion.Roles))
    }),
    Expires = DateTime.UtcNow.AddHours(8),
    Issuer = "https://api.lapluma.app",
    SigningCredentials = new SigningCredentials(signingKey, SecurityAlgorithms.RsaSha256)
};
var token = tokenHandler.CreateToken(tokenDescriptor);
```

TASK-P0-03: Add Security Definitions & Strict Scopes in API Gateway

Target: [PEN-lapluma_infra/infra/terraform/modules/gateway/main.tf](#) (Lines 20–271)

```
securityDefinitions:
  entra_jwt:
    type: "oauth2"
    authorizationUrl: ""
    flow: "implicit"
    x-google-issuer: "${var.oidc_issuer}"
    x-google-jwks_uri: "${var.oidc_jwks_uri}"
    x-google-audiences: "${var.oidc_audience}"
security:
```

```
- entra_jwt: []
# Retain empty security on public health checks:
paths:
  /catalog/healthz:
    get:
      security: []
```

TASK-P0-04: Implement Authentic RSA-SHA256 Signed URLs for Google Storage

Target: [PEN-lapluma_infra/src/workflow-api/GoogleCloudStorageUploadUrlIssuer.cs](#) (Lines 55–59)

```
// REPLACE raw SHA256 hex digest with Google Cloud IAM SignBlob API call:
var iamClient = await IamCredentialsClient.CreateAsync();
var signRequest = new SignBlobRequest {
    Payload = ByteString.CopyFromUtf8(canonicalString),
    Name = ServiceAccountName.Format(projectId, serviceAccountEmail)
};
var signResponse = await iamClient.SignBlobAsync(signRequest);
var signature = Convert.ToHexStringLower(signResponse.SignedBlob.ToByteArray());
```

TASK-P0-05: Enforce Tenant ID Scoping in Workflow SQL Queries

Target: [PEN-lapluma_infra/src/workflow-api/PostgresWorkflowSource.cs](#) (Lines 50–54, 148)

```
// Add tenantId parameter and SQL clause:
WHERE f.tenant_id = $1 AND ($2::text IS NULL OR f.display_label ILIKE '%' || $2 || '%')
// Remove hardcoded "tenant_clinic_alpha" in CreateClientFolderAsync
```

TASK-P0-06: Disable Public IPv4 & Enforce SSL on Cloud SQL

Target: [PEN-lapluma_infra/infra/terraform/modules/database/main.tf](#) (Line 20)

```
ip_configuration {
  ipv4_enabled = false
  private_network = var.vpc_network_id
  ssl_mode     = "ENCRYPTED_ONLY"
}
```

TASK-P0-07: Unblock Pub/Sub Push Ingress on Processing Worker

Target: [PEN-lapluma_infra/infra/terraform/modules/compute/main.tf](#) (Line 143)

Set `ingress = "INGRESS_TRAFFIC_ALL"` on `processing_worker` so Google Pub/Sub push delivers successfully while enforcing Cloud Run IAM invoker authentication.

TASK-P0-08: Restore Applicant Authentication by Removing Consumer Domain Ban

Target: [PEN-lapluma_app/apps/ios/AptureApp/Features/Onboarding/RegistrationView.swift](#) (Lines 258–274)

Separate consumer applicant sign-in from workforce clinic sign-in. Allow consumer applicants with [@gmail.com](#) and [@outlook.com](#) to register and log in with Passkeys without blocking them.

Category 2: P1 High-Priority Hardening (Sprint 1 Tasks)

Task ID	Target File	Description	Acceptance Criteria
TASK-P1-01	<code>OfflineCaseStore.swift</code>	Back in-memory draft store with AES-256-GCM disk persistence via <code>EncryptedLocalStore</code> .	Offline drafts survive app restart and memory termination.
TASK-P1-02	<code>LiquidGlassTokens.swift</code>	Read <code>@Environment(\.colorSchemeContrast)</code> and render high-contrast solid borders when active.	Passes WCAG AA contrast on Increase Contrast accessibility profiles.
TASK-P1-03	<code>FinishTogetherLiveCanvasView.swift</code>	Replace fixed 220pt frames with dynamic scaling and remove hardcoded 9pt/10pt fonts.	No text clipping or container overflow at Dynamic Type AX1-AX5.
TASK-P1-04	<code>messaging/main.tf</code>	Attach pull subscription to <code>lp-processing-dlq</code> with 14-day retention and grant publisher IAM.	Poison messages are captured in DLQ rather than dropped.
TASK-P1-05	<code>compute/main.tf</code>	Wire <code>Database_ConnectionString</code> from Secret Manager and switch <code>Catalog_Source</code> to <code>postgres</code> .	Cloud Run services connect to PostgreSQL instead of fixture stubs.
TASK-P1-06	<code>PostgresWorkflowSource.cs</code>	Persist step-up authentication challenges in PostgreSQL with 5-minute TTL and single-use invalidation.	Approval endpoint strictly rejects unverified or arbitrary challenge strings.
TASK-P1-07	<code>IStoredDocumentVerifier.cs</code>	Replace <code>PassThroughStoredDocumentVerifier</code> with authentic GCS metadata check.	Server verifies object existence and checksum before marking upload complete.
TASK-P1-08	<code>docs/adr/ADR-005.md</code>	Update status to <code>Status: Superseded by ADR-019</code> .	ADR index accurately reflects active GCP architecture.

Category 3: P2 Operational, Governance & Portal Tasks (Sprint 2)

Task ID	Target File	Description	Acceptance Criteria
TASK-P2-01	.github/workflows/deploy-pages.yml	Deploy public GitHub Pages landing portal with Scrivener notice and Document Library.	Public web portal accessible with LaPluma design tokens.
TASK-P2-02	SecureEnclaveAttestationSigner.swift	Migrate to hardware SecureEnclave.P256.Signing.PrivateKey and Apple App Attest.	Cryptographic attestation signed by hardware Secure Enclave.
TASK-P2-03	FinishTogetherLiveCanvasView.swift	Remove "Biometric Attestation" labeling and telemetry storage to comply with BIPA.	Zero biometric identifiers stored; full statutory BIPA compliance.
TASK-P2-04	PEN-lapluma_infra/azure.yaml	Retire Azure Bicep scaffold, remove Azure Functions, and prune obsolete Azure CI steps.	Repository contains only active GCP Terraform and Cloud Run code.
TASK-P2-05	security-scanning.yml	Configure Trivy and Checkov to scan infra/terraform/ instead of Azure ARM templates.	CI/CD security scan evaluates active GCP infrastructure.
TASK-P2-06	PEN-lapluma_infra/docs/runbooks/	Author GCP Disaster Recovery, Database Zonal Failover, and Secret Rotation runbooks.	Operators have executable, verified GCP recovery procedures.
TASK-P2-07	PEN-lapluma_app/tools/check-swift-static.py	Implement authentic SBOM dependency check against Package.resolved in CI.	Fails CI build on any unapproved third-party package addition.